

Entity-conditioned nulls for anomaly detection in authentication logs

Abstract

Anomaly detection on security telemetry is usually posed as outlier detection against a pooled population. We argue and then measure that this asks the wrong question: an account that is permanently unusual is not thereby suspicious, and an account that has changed is suspicious whether or not it is unusual for the organisation. We condition each null on the entity that produced the event, so the reference set for an authentication is that account's own history.

On the Los Alamos authentication corpus, where 549 labelled red-team events occur among 4.19 million scored events, a per-entity novelty test attains 15.7% precision (95% CI 9.0–26.0) at 10 alerts per analyst-day against a base rate of 1.31×10^{-4} , a lift of about 1,200. A structural census locates the mechanism: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, while the property a population-rarity test expresses contains none of them.

Five negative results are of independent interest. Combining the arms' p-values, by Fisher's method or by the Šidák-corrected minimum, never exceeds the best single component; alerting whenever any arm ranks an event highly is dominated at equal cost and superior at equal depth, at 3.7 times the volume; and dividing the budget by demonstrated quality fails too, bounded rather than merely observed, since an exhaustive search over splits chosen with the labels in hand finds the optimum at the corner. What decides whether a division pays is the overlap between two arms' detections — 74.6% between the two strongest, 0% where a split does win. Read as a zero-sum game against an adversary choosing the mechanism, that corner result is a theorem rather than a measurement, and the conclusion usually drawn from it is also wrong: the best single arm guarantees nothing at all.

Keywords: anomaly detection; multiple testing; conditional inference; game theory; intrusion detection; decision theory.

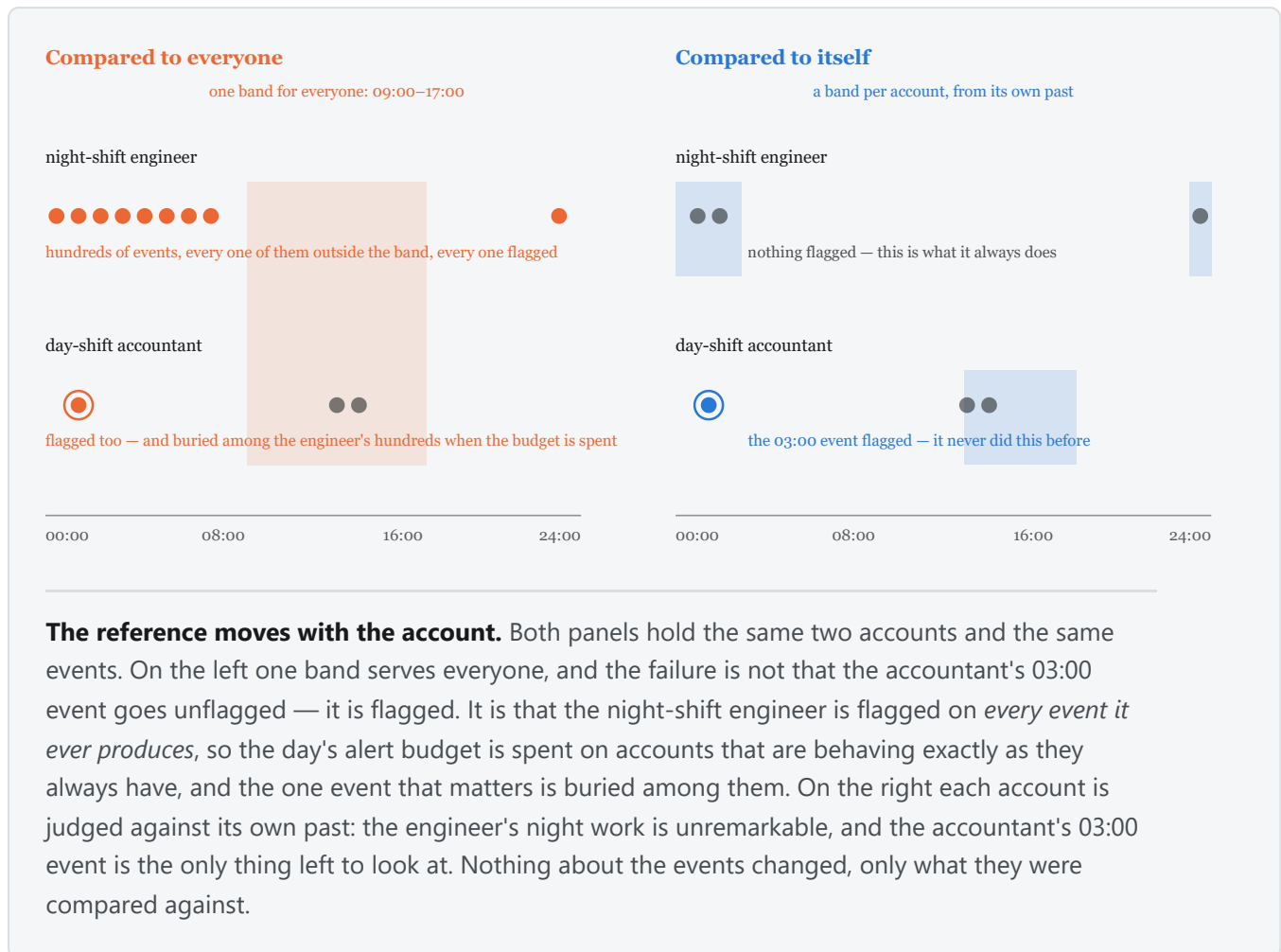
1. Introduction

An enterprise authentication log records who authenticated to what, from where, and how. Two features of the setting bound what any method can achieve.

Volume against rarity. 42.2 million events were scored over seven days and 549 are labelled, a base rate π of 1.30×10^{-5} . With α the per-event false-alarm rate, $P(\text{intrusion} \mid \text{alarm}) = \pi / (\pi + (1 - \pi) \cdot \alpha)$, so half a queue is real only at $\alpha \approx 1.3 \times 10^{-5}$ — about 78 false alerts a day. At $\alpha = 10^{-3}$, typical of published detectors, the same corpus yields some 6,000 false alerts against 78 real ones. This is Axelsson's base-rate argument [1] on our own data.

A fixed working day. Triage capacity is a staffing constant, not a tuning parameter, which is why every comparison here is at a matched number of alerts per analyst-day and never at a matched threshold: two methods thresholded alike may emit volumes differing by three orders of magnitude, and the comparison would then be between their volumes.

1.1 Why a population-scope null asks the wrong question



A systems administrator who works nights and authenticates to database servers no one else touches is a persistent outlier and not an intruder; an account whose behaviour has just changed completely may still sit inside the population's bulk, because the values it moved onto are ordinary for other people. Both errors have one cause: "is this event unusual for this organisation" is not "has this account departed from its own behaviour". The two differ in the reference set against which an observation is judged exchangeable — all accounts, or one account's history. Conditioning on the entity is this paper's whole commitment.

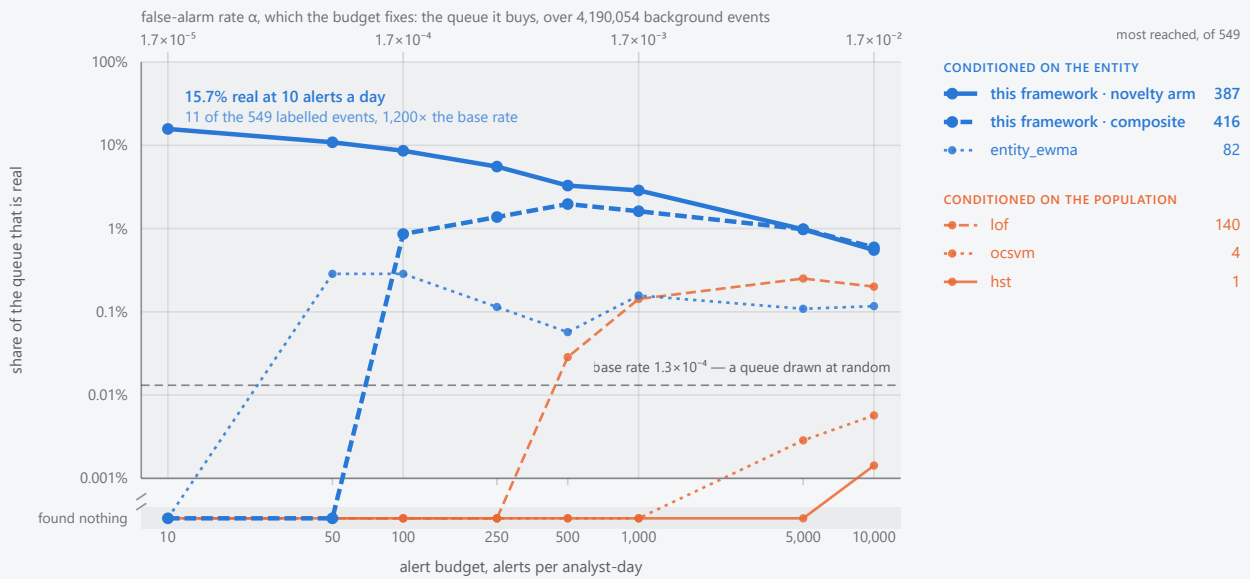
Seven questions are asked of each event, each returning a p-value under its own null or abstaining. Section 4 gives the estimators.

ARM	ASKS	SCOPE
novelty	has this account used this categorical value before?	per-entity
noveltyrate	is it producing first-ever values faster than it historically does?	per-entity
pairing	has this account combined these two values before?	per-entity
timing	is this hour unusual for this account?	per-entity
volume	is this much activity in this window unusual for this account?	per-entity
drift	has this account's rate shifted upward and stayed there?	per-entity
marginal	is this value rare across the whole population?	population

1.2 What this paper establishes

Share of the alert queue that is real, at each alert budget

4,190,603 events scored over 7 days · 549 labelled · a base rate of one in 7,633. Grouped by the scope of the null each method tests.



The comparison is a function of the budget, not a point. Every line is measured on the same slice: 4,190,603 scored events over 7 days, of which 549 are labelled, a base rate of one in 7,633. Each point is one method at one measured budget. A method that found nothing at a budget is drawn on the *found nothing* row below the axis break rather than omitted, so a flat line there reads as measured rather than as missing; the methods leave that row at six different budgets, which is the comparison this figure exists to make.

Colour is the scope of the null, not who wrote the method. Blue judges an event against the history of the account that produced it, orange against the pooled population (§1.2). `entity_ewma` is a comparator drawn in blue because it keeps a per-entity mean; this framework's arms are the heavier strokes in that family, and every method's scope is recorded in the curve file. A method's own α is lower than the budget's by the detections it found, at most 16% at 10 alerts a day and 0.6% at 10,000.

The figure draws the four comparators with the most detections over the budget range, so the choice does not flatter this framework; the other four reached too little to plot, and the table below lists all eight that were run. *Every reading here is an upper bound on this framework's disadvantage and a lower bound on its precision.* The corpus has no true negative class, so an unlabelled alert on genuine but unrecorded malicious activity counts as a false alarm (§12.5). The baselines read a fixed-length numeric vector per event and only `entity_ewma` holds per-entity state; they are not held to R2 or R4 (§12.4).

METHOD	JUDGED AGAINST	100 ALERTS / ANALYST-DAY			1,000 ALERTS / ANALYST-DAY		
		FOUND	PRECISION	RECALL	FOUND	PRECISION	RECALL
this framework, novelty arm	its own history	60	8.6%	11%	201	2.9%	37%
this framework, composite	its own history	6	0.86%	1.1%	113	1.6%	21%
entity_ewma	its own history	2	0.29%	0.36%	11	0.16%	2.0%
lof	the population	0	0	0	10	0.14%	1.8%
ocsvm	the population	0	0	0	0	0	0
hst	the population	0	0	0	0	0	0
rref	the population	0	0	0	0	0	0
eif	the population	0	0	0	0	0	0
iforest	the population	0	0	0	0	0	0
pca	the population	0	0	0	0	0	0

Every method that was run, at two budgets. A budget of b alerts per analyst-day buys a queue of $b \times 7$ alerts over the 7 days scored, whichever method spends it. *Found* is labelled events reached, *precision* the share of the queue that is real, and *recall* the share of the 549 labelled events reached.

Most of the comparators reach nothing at all: seven of the eight at 100 a day and six of the eight at 1,000 a day. A zero is measured, not missing — every method read the same events, which is why the figure above needs a row below its axis.

This framework's novelty arm reaches 11% of the campaign at 100 alerts a day and 37% at 1,000, against a base rate of 1.3×10^{-4} — a lift of $650\times$ and $220\times$.

Recall counts what the red team wrote down, not what happened. The label file records an authorised exercise rather than annotating the log exhaustively, so unrecorded malicious activity counts against precision and is absent from the recall denominator (§12.5): both columns are lower bounds. Only `entity_ewma` holds per-entity state, and no comparator is held to R2 or R4 (§12.4).

The figure tracks each method across the operating range; the table fixes two budgets and includes every comparator the figure has no room to draw. Three results follow. Per-entity conditioning is worth a great deal, and the population arm is not merely weaker but *empty* on the real campaign, since no labelled event holds a population-rare value (Appendix B). Combining or dividing evidence never beats the best single arm, and under a known attack mix that is forced rather than measured. And the best single arm nonetheless guarantees nothing against an adversary who picks the mechanism — a coverage defect rather than an allocation one.

We do not claim state-of-the-art detection: 15.7% precision at the tightest budget is good against this base rate and not good enough to act on unattended. We do not claim that population-scope conditioning is useless — it retains one capability this framework lacks (§2.5) — nor generalisation beyond telemetry of this shape, nor to the full population: every figure is from an entity subset (Appendix A).

2. Results

All comparisons are at matched alerts per analyst-day over a seven-day window, so a budget of B corresponds to $7B$ alerts. Corpora, windows and sampling are in Appendix A; the six framework requirements referred to as R1–R6 are in Appendix C.

2.1 Detection on the real campaign

`lanl-r11-b1000-weighted-d7-14-005`, 549 labelled among 4,190,603 scored. Every proportion carries a 95% Wilson interval [7]; Appendix F states why those intervals are optimistic.

ARM	10/DAY	100/DAY	1000/DAY	PRECISION AT 10/DAY	RECALL AT 1000/DAY
novelty	11	60	201	15.7% (9.0–26.0)	36.6% (32.7–40.7)
pairing	4	59	127	5.7% (2.2–13.8)	23.1% (19.8–26.8)
noveltyrate	0	22	185	—	34.9% (31.0–39.1)
timing	1	2	7	1.4% (0.3–7.7)	1.3% (0.6–2.7)
volume	0	0	0	—	0.0% (0.0–0.7)
marginal	0	0	0	—	0.0% (0.0–0.7)
corrected minimum	4	47	162	5.7% (2.2–13.8)	29.5% (25.8–33.5)
composite	0	6	113	—	20.6% (17.4–24.2)

At the tightest budget `novelty` returns 11 true positives in 70 alerts, a lift of about 1,200; precision falls to 2.9% at 1000 alerts a day as recall rises to 36.6%, the ordinary consequence of taking a longer prefix of one ranking. `novelty` and `pairing` are **not distinguishable and should not be ranked** — at 100 alerts a day their recalls are 10.9% (8.6–13.8) and 10.7% (8.4–13.6), and a novel pairing is a novel value of a composite field. The `volume` and `marginal` zeros carry an upper bound rather than a point. The composite's zero at the two tighter budgets is not an artefact calibration removes: those figures are *with* conformal calibration, and without it the composite reaches 0 at 100 a day rather than 6.

On a corpus differing in background (`holdout-r7-fixed`, 262 labelled among 1,427,225) `novelty` gives 2, 8, 15 and 21 at 10, 25, 50 and 100 alerts a day and the composite 0 everywhere.

2.2 Detection by attack mechanism

Planted attacks of six named kinds separate "cannot express this mechanism" from "cannot afford it": eight victims each, inside the scoring window, with the planted value always the most population-common value the victim has never used, so population rarity is held out by construction (Appendix A). `lanl-inj-b1000-weighted-d7-14-005`.

The budget binds harder than the method. At 10 alerts a day no arm reaches any planted mechanism; at 100 exactly one is reached, account takeover, by the `marginal` (76) and the composite (26); at 1000 five of six are. For four of the six, "this framework does not detect it" is false at some budget and true at another, and only the budget changed.

At 1000 alerts a day, planted totals in the header. Every row spends the permitted 7,000 alerts except the equal-depth union, which spends 31,505 ($\times 4.5$), and the baselines, measured at their own budgets on the sampled corpus of §2.5.

METHOD	SPRAY /320	LATERAL /40	OFF-HRS /64	PRIV-ESC /24	LOW+SLOW /288	TAKEOVER /120	REAL ,
novelty	80	15	0	0	0	30	178
noveltyrate	117	26	0	4	0	64	173
pairing	0	0	0	0	0	12	130
timing	0	0	3	0	0	11	7
volume	0	0	0	0	0	0	0

METHOD	SPRAY /320	LATERAL /40	OFF-HRS /64	PRIV-ESC /24	LOW+SLOW /288	TAKEOVER /120	REAL
drift	pending	pending	pending	pending	pending	pending	pending
marginal	0	0	0	0	0	120/120	0
composite	0	4	0	0	0	116	107
corrected minimum	40	10	0	0	0	28	156
union, all arms, equal cost	0	0	2	0	0	120/120	99
union, all arms, equal depth	117	26	3	4	0	120/120	265
lof — baseline	0	0	0	0	12	0	0
ocsvm — baseline	0	0	0	0	0	33	0

Pending measurement. The `drift` row is the sequential-change arm of §3.3, whose replay (`lanl-inj-b1000-drift-d7-14-006`) is running as this draft is rendered; its low-and-slow cell decides whether §2.3's game value stays at zero. The plant adds a fixed twelve events a day for three days rather than a fixed fraction, so the arm's power here scales inversely with the victim's baseline volume — +42% on the smallest victim the design permits, far less on a busy one — and a partial result is the expected outcome.

No single method is best at more than one thing. The `marginal` takes every planted takeover and nothing else; `noveltyrate` takes spray, lateral movement and privilege escalation; `novelty` takes the real campaign. A reader looking for one row to deploy will not find one, which is what §2.3 formalises. And **low-and-slow is reached by no arm at any budget** — 0 of 288, 0 of 8 victims. It is the mechanism `volume`'s over-dispersion is built to tolerate, so this is a confirmed prediction; §3.3 reports that its response is in addition *inverted*, and the statistic that repairs the direction.

The `marginal`'s 120 of 120 needs explaining, since population rarity is held out by construction. Its median p-value is 0.59 on spray and lateral movement, which substitute the destination computer, 0.17 on privilege escalation, which substitutes the authentication type, and 3.8×10^{-5} on takeover, which substitutes three at once: the pattern follows the **cardinality of the substituted field**. Destination takes 3,535 distinct values, so a common value the victim has not used is genuinely common; authentication and logon type take 14 and 10, with three values accounting for 99.6% of resolved authentication types, so an account already using the common ones can only be given a tail value. **Holding population rarity out succeeds where the vocabulary is large and cannot where it is small** — a limitation of the planted corpus, stated because the alternative is to read the row as evidence for a mechanism the design excludes.

2.3 Allocation under an adversarial mix

Read the table above as a payoff matrix — rows arms, columns the mechanism an adversary chooses, entries $P(\text{detected} \mid \text{mechanism})$. Under a known mix p the expected detection of a randomised allocation w is $w^T(Ap)$, **linear in w **, and a linear form on a simplex attains its maximum at a vertex. So no prior-weighted mixture, including one fitted to published incident statistics, can beat the best single arm; checked over 20,000 random priors, none does. The equilibria are the minimax solutions [18] by Dantzig's reduction [19]: `robust-inj-d7-14-002` for the framework's own arms, `robust-inj-lof-d7-14-001` for the variant admitting a baseline.

The game's value is exactly zero. Every arm scores 0 on low-and-slow, so the saddle point is (any arm, low-and-slow) and a rational adversary wins with certainty. No reweighting of rows changes a column of zeros: the defect is coverage, not allocation, which is why §2.4's negative result cannot be repaired by a better rule. Maximin is therefore degenerate, returning 0 for every allocation.

What is well posed is to normalise each mechanism by the best rate any arm reaches against it and maximise the worst-case *fraction retained*, dropping the mechanism no arm reaches since every allocation ties at zero there:

OBJECTIVE	GUARANTEE	EXPECTED RATE	ALLOCATION
best single arm	0	0.372	any one arm — each is blind to some mechanism
competitive ratio	0.421 of achievable	0.217	noveltyrate 0.42, timing 0.42, marginal 0.16

Expected rate is under a prior weighted towards credential attacks and takeover. The optimum **equalises**, which is what makes a single number mean something:

SPRAY	LATERAL	OFF-HRS	PRIV-ESC	TAKEOVER	REAL
0.421	0.421	0.421	0.421	0.421	0.426

Five of six sit exactly at the guarantee; the real campaign is not binding, and low-and-slow is absent because excluded rather than covered.

Coverage is purchasable, and not by reweighting. Labelled events found on the planted corpus at 1000 alerts a day, against the worst mechanism's retained fraction:

RULE	FOUND	ALERTS	WORST-CASE RETAINED
best single arm (noveltyrate)	384	7,000	0
randomised, even over the two best arms	344	7,000	0
corrected minimum	234	7,000	0
composite	227	7,000	0
union, all arms, equal cost	221	7,000	0
randomised, competitive-ratio mixture	189	7,000	0.421
union, all arms, equal depth	535	31,505 (×4.5)	1.000
per-entity routing, oracle floor–ceiling	448–535	7,000	—

No rule in §2.4 guarantees anything at all. Two allocations do, and the table prices both: retain 42.1% of the achievable on every reachable mechanism at the same budget for 42% of the expected detection, or buy the guarantee outright at 4.5 times the alerts.

Two further readings. **Randomising is not dividing, and only dividing had been tested** — §2.4 measures unions and splits, which give every arm a fraction of its depth, whereas a mixed strategy runs one arm at full depth chosen by lottery and is exactly evaluable from detections already recorded. It finds 344 against the best combination rule's 234 at the same spend, and still loses to the best single arm, which linearity requires. And **routing is not a global allocation**: it chooses per entity, so it can send an established account to a per-entity null and a cold one to the population null and collect both, which makes it the only construction here able to exceed the best single arm at equal cost. Its floor is what any per-entity policy matches by construction and its ceiling is the union at full depth; both are oracles charging no alert cost.

Admitting a low-and-slow-capable arm prices the excluded column. With **10f** from §2.5 admitted every mechanism is reachable and the guarantee over all seven falls to **0.296 at 59%** of expected detection: covering the hole is expensive, and the two figures bracket the choice rather than settling it. **10f** comes from a hundredfold easier sampled problem, so it is an existence proof rather than a matched comparison, which is why the framework's own arms carry the primary result.

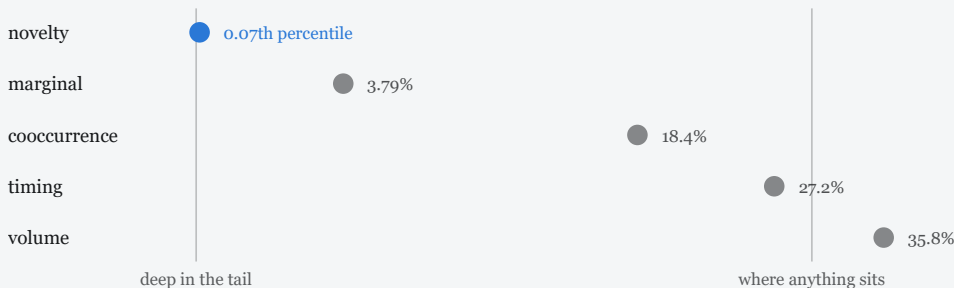
Pending measurement. A third strategy set — the framework's arms plus the sequential-change arm of §3.3, which is the framework's own attempt at the excluded column — is the one that matters, and its replay is running as this draft is rendered. If that arm reaches low-and-slow at all, the value of the game

ceases to be zero without appeal to a baseline, and the guarantee and its price are restated over all seven mechanisms.

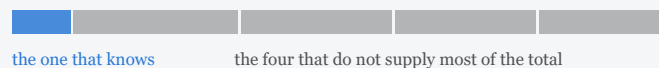
Two properties of the equilibrium are reported in Appendix G: what happens once the adversary is charged for the mechanism it picks, which removes low-and-slow from its reply and concentrates the allocation on **timing**; and where the next unit of detector work is worth spending, which is in none of the columns §2.1 and §2.2 compare arms on. **Marginal improvement to novelty against noveltyrate**, which is what §2.1's headline turns on, has a shadow price of exactly zero.

2.4 Why combination and allocation do not help

where each detector puts one labelled event, in its own distribution



Fisher adds all five contributions together:



At 100 alerts a day, of 262 labelled events: novelty alone 21 · most-extreme-of-five 20 · the five-detector sum 0

More evidence is not better when most of it is not evidence. Fisher's method asks whether the evidence is jointly unusual, which is the right question only when every detector is informative. Here one is: it places the median labelled event at the 0.07th percentile of its own distribution, more extreme than 99.93% of all traffic. The other four place it where any event would sit. The sum is dominated by the four, so a composite built from a component that finds 21 labelled events finds none — and no cleverer combiner recovers it, because the remedy is not a better average but not averaging in detectors that know nothing.

RULE	10/DAY	100/DAY	1000/DAY	ALERTS AT 1000/DAY
best single arm	11	60	201	7,000
union, per-entity arms, equal cost	2	27	106	7,000
union, all arms, equal cost	2	21	96	7,000
union, per-entity arms, equal depth	11	74	278	25,930 (×3.7)
union, all arms, equal depth	11	74	278	32,134 (×4.5)

At equal cost the union is strictly dominated at every budget, with non-overlapping intervals at the widest: recall 17.5% (14.5–20.9) against 36.6% (32.7–40.7). No exchange rate rescues a dominated option. At equal depth it finds what no single arm finds, 278 against 201, for 3.7 times the alerts.

The two p-value rules fail for different reasons. **Fisher's sum averages an informative test with uninformative ones:** labelled events sit at the 0.07th percentile of **novelty**'s own distribution and between the 18th and 36th of every other arm's, so summing $-2 \ln P$ over six tests dilutes one signal with five non-signals — Fisher's method is powerful against diffuse alternatives and the minimum against sparse ones, and this

alternative is sparse. **The corrected minimum compares p-values across tests sharing no scale:** `novelty` supplies 5,979 of the 7,000 retained alerts and `volume` never supplies the minimum at all. Removing the scale mismatch made the `marginal` 's signal reachable and the equal-cost result got *worse*, so it was not the binding defect.

Dividing by demonstrated quality fails too, and the failure is bounded. A per-alert likelihood ratio fitted per arm on burn-in (Appendix D) loses at every budget on both corpora:

RULE	R11 100/DAY	R11 1000/DAY	INJ 100/DAY	INJ 1000/DAY
best single arm	60	201	76	384
weighted, burn-in weights	56	164	56	231
weighted, oracle weights	61	174	61	309
best two-arm split, oracle	60	201	77	395

Refitting the weights on the evaluation labels — an oracle — separates the arms properly, 0.19, 0.22 and 0.23 for the per-entity arms against 0.71 for `timing` and 1.0 for `volume`, and the rule still loses. **The construction fails, not the fit.** An exhaustive search over two-arm splits, again oracular, finds the optimum on the real campaign at the corner at both budgets, and diverting 5% costs 13 detections at 1000 a day, so the derivative is negative *at* the corner.

The mechanism is that **the arms are substitutes rather than complements** — 74.6% of `noveltyrate` 's detections are also found by `novelty` and 78.7% of `pairing` 's are, so splitting halves each arm's depth and what survives largely coincides. Where the arms genuinely are complements the same search finds headroom, which is the control this argument needs: the `marginal` 's 76 detections at 100 alerts a day overlap the per-entity arms' by **zero**, and the best split gives it 75 alerts and `novelty` 25, for 77 against 76; at 1000, 150 and 850 for 395 against 384. Both optima sit on a plateau, both gains are inside sampling error, and both are on planted rather than real attacks. **Overlap decides whether dividing a budget can pay.**

2.5 Population-scope baselines

Eight reference implementations spanning four inductive biases were run on the same events with the same labels and budgets: isolation forest [11], extended isolation forest [12], half-space trees [13], local outlier factor [14], one-class SVM [15] and PCA reconstruction error, from scikit-learn [16], plus an uncalibrated per-entity EWMA z-score.

On the matched comparison all six population models detect **0 at every budget**, which Appendix B's census explains. On the planted corpus the exception is the interesting one — one-class SVM reaches 33 of 120 takeovers and **local outlier factor 12 of 288 low-and-slow events, the one mechanism no arm of this framework reaches at any budget.** A sustained small departure is what `volume` 's over-dispersion tolerates and what a density estimate does not: a capability this framework lacks, and why the two scopes are complementary rather than ordered. Both figures come from an easier problem in the way that dominates — a 1-in-100 sample of 45,071 rows rather than 4.49 million events, raising the labelled share from 0.031% to 3.1%.

3. Discussion

3.1 What the evidence supports

Conditioning each null on the entity is supported on this campaign, and specifically: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, and the property a population-rarity test expresses contains none of them. That direction is what the evidence establishes, and it is narrower than "per-entity beats population conditioning" — on planted attacks the population test detects a mechanism no entity-scope test here reaches, and a population density estimate reaches a second.

Combining evidence is not supported: five rules, none exceeding its best component at equal cost at any budget. Allocation is not supported either, and §2.3 states why independently of this corpus: the objective is linear in the allocation, so its optimum is a single arm. What §2.3 adds is that the corollary usually drawn — deploy the best arm — is also wrong. Both point at the same place: **coverage, not allocation**.

3.2 Principal limitations

Appendix F carries the full set with the measurement establishing each. Two dominate.

The novelty p-value is confounded with history length. For a first-ever value the estimate reduces to $a/(n + a(K+1)) \approx 1/n$. Across 32 planted victims spanning 263 to 20,666 events of history, the product of the p-value and the history length has median 1.15 and lies in [0.50, 7.22]: among novel events the ranking is close to sorting accounts by event count. Clearing the arm's realised cut needs of the order of 10^5 events of history and the busiest planted victim had 20,666, so **no attack on an ordinary account could win an alert slot regardless of what it did**. It is not straightforwardly fixable — reserving unseen mass by Good–Turing rather than by a fixed concentration *lost* detections, because large histories carry many singletons and the correction therefore judges a first-ever value unremarkable for exactly the accounts the working estimator ranks highest. The working configuration works for a reason the model does not state.

A sustained intrusion enlarges its own reference set. State is committed after scoring, so an event is judged against a history that excludes it — but the next event of the same campaign is not. Over a campaign persisting for days on one account the reference distribution drifts toward the attacker's behaviour. This is an untested alternative explanation for two null results, the low-and-slow zero in particular, and cannot be separated from the stated mechanism without a run that freezes per-entity state across the campaign window.

3.3 What is repaired, and what a deployable version needs

Two arms of §2.2 are **not evidence about per-entity conditioning in either direction**, and their zeros should be read as unmeasured. `timing`'s tail mass was floored by its own 512-point grid at 9.77×10^{-4} against a realised cut of 1.00×10^{-3} at 10 and 100 alerts a day: it could not alert whatever it observed. Standardising the event's $\ln U$ by the mean and spread of the $\ln U$ this entity's own events received removes the floor and takes detections from 0, 0 and 6 to 1, 2 and 7 on the real campaign and from 0, 1 and 12 to 2, 9 and 21 on the planted corpus, and the off-hours response improves rather than being traded away: median p falls from 3.20×10^{-2} to 8.23×10^{-3} , widening the separation from the nearest other mechanism from 5.7 to 18.6.

`volume` is misspecified in the opposite direction — 27,464 background events on `r11` fall below 10^{-12} where a calibrated null predicts 4.2×10^{-6} and no labelled event goes below 1.96×10^{-7} , so its queue fills with background before a labelled event can compete, and an abstention gate accounts for none of it. Its response to low-and-slow is in addition **inverted**, median p 0.72 against 0.29 elsewhere.

That needs a statistic it does not contain rather than a refit: an over-dispersed marginal test of one period cannot see a drift small in every period, because the evidence is in the sequence. Page's one-sided cumulative sum [17] accumulates it — with baseline λ_0 and target shift ρ the reference is $k = \lambda_0(\rho - 1)/\ln \rho$ and $S_t = \max(0, S_{t-1} + k_t - k)$, so a sustained shift grows S linearly in the number of periods while the spread of its null grows as the square root — and the p-value is the upper tail of S standardised against the entity's own sums. On synthetic streams fitted on identical stationary history, **it separates a sustained +30% shift from matched stationary variation by 237× where the volume predictive separates it by 1.2×**.

Two details earn that, and both are cases of a null that must not be allowed to follow the thing it measures. The running period is charged the whole reference value while contributing only the events seen so far, so the scored statistic is commensurable with a null built from closed periods. And the null over S is not discounted while the baseline rate is — a discounted reference distribution tracks the change it exists to detect, §3.2's second limitation in acute form, and undiscounting it is what takes the separation from 2× to 237×.

Pending measurement. The arm is wired into the replay and its corpus run (`lanl-inj-b1000-drift-d7-14-006`) is in flight as this draft is rendered, so §2.2's `drift` row and §2.3's third strategy set are not yet filled. One limitation is already known: a seven-day burn-in leaves an entity with seven closed

periods at the boundary and the arm's null needs eight, so its first scored day is a column of abstentions. Lowering the gate to seven would recover that day and would be fitting a parameter to the length of one corpus's burn-in. The routing policy of §2.3 is implemented but not scored: its harness needs a per-entity burn-in pass and a choice about how alerts are charged, and choosing that against the evaluation labels is the defect Appendix F lists.

One gap separates what is measured from what can be run: **a fixed budget is a batch construction**. Selecting the top B of a day requires the whole day, and an operator at 14:00 does not know what arrives by 23:59; the same objection applies to a per-day Benjamini–Hochberg step-up. §4.4's objective does not have this defect and Appendix D's score is built to the same constraint. What remains missing is a calibrated per-alert probability.

One direction is closed rather than open. Learning the allocation online is the adversarial bandit setting [20], whose regret $\sqrt{(2TK \ln K)}$ looks survivable — 89 detection-units against 10,481 available over a year at $K = 6$. The bound assumes the reward is observed each round, and it is not: labels are the object of the search, feedback is bandit-only, and separating the top two arms of §2.1 at 80% power needs about 41,000 labelled events per arm against 549. **A learner cannot converge to an equilibrium it lacks the samples to see**, so the allocation must be stated rather than learned.

4. Method

4.1 The entity-conditioned null

Write an event as field–value pairs with an entity e and a time t . For each field the framework maintains a per-entity summary of e 's history, decayed exponentially in event time with a seven-day half-life, and asks H_0 : *this observation is exchangeable with e 's own decayed history for this field.* Nothing is specific to authentication — what makes a question available is the inferred kind of the field, not its name.

ARM	PREDICTIVE
novelty	Dirichlet–multinomial over decayed counts; a first-ever value receives the reserved mass $a/(n + a(K+1))$
noveltyrate	Beta-binomial over e 's own rate of producing first-ever values, on an hourly window
pairing	novelty 's estimator on a synthetic composite field, so the question stays per-entity
timing	von Mises KDE on the 24-hour circle, as a truncated Fourier series; bandwidth 1.5 h
volume	Gamma–Poisson over e 's completed periods, deliberately over-dispersed
drift	Page's one-sided cumulative sum over per-period counts, standardised against e 's own sums
marginal	the same Dirichlet form over decayed <i>population</i> counts

Two properties are load-bearing. novelty 's reserved mass is $\approx 1/n$, so **the p-value for a first-ever value is set by the length of the account's history rather than by how surprising the value is** (§3.2); noveltyrate exists because of that weakness and asks a scale-free question instead. And volume 's over-dispersion makes it tolerant of ordinary bursts and blind to sustained small increases, which §2.2 confirms and §3.3 addresses.

An arm may score several fields; it takes the most extreme, with a Šidák correction where it combines fields internally.

Ordering is the leakage control: every arm scores against pre-event state, the combination is computed, and only then are observations committed. A first-ever value is therefore still novel when scored. The rule cuts the other way too, which is §3.2's second limitation.

4.2 Field inference and abstention

R2 requires that no component be told a field's type. A registry observes values as they arrive and settles each field into one of five kinds — categorical, boolean, discrete, continuous, identifier — after which arms iterate the registry rather than a list of names.

The identifier kind carries the weight. A field whose values are almost all distinct — a session GUID, a request id — is unbounded by construction: every value is first-ever, so a novelty test on it fires on every event and, being the most extreme thing in the queue, consumes the whole budget. Arms decline such fields. Without that, the framework's headline arm is a random-number generator with a large p-value.

R3 makes abstention an outcome: it reduces the number of tests combined rather than contributing a p-value of one. At this base rate that matters, because a neutral value entered into a combination over six tests is not neutral but evidence of ordinariness, and in Fisher's sum five such values bury one informative test.

4.3 Combination and calibration

RULE	STATISTIC	WHAT IT ASKS
composite	Fisher's $X^2 = -2 \sum \ln P_j$ on $\chi^2(2J)$, with Brown's correction [3, 4]	is the evidence <i>jointly</i> unusual?
corrected minimum	$P = 1 - (1 - \min_j P_j)^J$, Šidák [5]	did <i>any</i> arm find <i>e</i> out of character?
union, equal cost	best rank in any arm, truncated to the shared budget	the same, with the p-value scale removed
union, equal depth	best rank in any arm, every arm keeping its own top <i>B</i>	the same, paying for the depth

Brown's correction requires a positive variance estimate for X^2 and does not get one here: with six arms the burn-in covariance implies $\text{Var}[X^2] = -27.5$, which no joint distribution can produce. The correction is then not applied and the combination degrades to plain Fisher, so **every composite figure in this paper is Fisher's statistic without Brown's correction**; Appendix F reads the negative estimate.

A fused rank is not calibrated against any of these nulls and carries no tail-probability interpretation; it reports a selection, and each alert still carries the p-value of the arm that raised it. Rank collisions are structural — every arm has a rank 1 — and break on event identity rather than on log *P*.

Conformal calibration [6] is applied optionally and orthogonally, replacing each arm's model tail with that value's rank in its own burn-in distribution, which is super-uniform whether or not the model is correct. Being monotone it cannot change any arm's own ordering, so per-arm figures are identical with and without it; what it changes is which arm supplies the minimum. It floors every p-value at $1/(n+1)$.

4.4 The decision problem

R6 states that alert volume follows from a stated exchange rate rather than a quota, because quotas are pathological: a system tuned to emit 100 alerts a day emits 100 on a quiet day too, all benign. If nothing happened, the right number of alerts is zero. We score an alerting configuration by $U = v \cdot \text{TP} - c \cdot \text{FP}$, with *v* what catching one incident is worth and *c* what one wasted investigation costs. Only *v/c* is identifiable from counts, so an operator supplies one number, and a queue is worth reading exactly when $\text{TP}/\text{FP} > c/v$.

Maximising a ratio does not work, and the failure is structural. TP/FP is precision under the monotone transform $P/(1-P)$, and precision's maximiser is the smallest queue containing a true positive; forbidding $\text{TP} = 0$ moves that corner from "alert on nothing" to "alert on one thing". **Any objective that is a function of precision alone is scale-free, and a scale-free quantity cannot say how many rows to show.** The same disposes of accuracy, balanced accuracy, F1 and Youden's *J* — each an unstated exchange rate wearing a metric's clothes; alerting on nothing scores 99.9987% accuracy.

A budget is therefore a **ceiling rather than a quota**: within it the queue is truncated where marginal alerts stop paying. Appendix E measures what that costs and buys at $v/c = 10$, stated in advance.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM Conference on Computer and Communications Security, 1999.
 2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events Data Set*. Los Alamos National Laboratory, 2015. CCo 1.0.
 3. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
 4. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
 5. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. Journal of the American Statistical Association 62(318), 1967.
 6. Vovk, V., Gammerman, A. and Shafer, G. *Algorithmic Learning in a Random World*. Springer, 2005.
 7. Wilson, E. B. *Probable inference, the law of succession, and statistical inference*. Journal of the American Statistical Association 22(158), 1927.
 8. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate: a practical and powerful approach to multiple testing*. Journal of the Royal Statistical Society B 57(1), 1995.
 9. Benjamini, Y. and Yekutieli, D. *The control of the false discovery rate in multiple testing under dependency*. Annals of Statistics 29(4), 2001.
 10. Chernoff, H. *On the distribution of the likelihood ratio*. Annals of Mathematical Statistics 25(3), 1954.
 11. Liu, F. T., Ting, K. M. and Zhou, Z.-H. *Isolation Forest*. IEEE International Conference on Data Mining, 2008.
 12. Hariri, S., Carrasco Kind, M. and Brunner, R. J. *Extended Isolation Forest*. IEEE Transactions on Knowledge and Data Engineering 33(4), 2021.
 13. Tan, S. C., Ting, K. M. and Liu, T. F. *Fast anomaly detection for streaming data*. International Joint Conference on Artificial Intelligence, 2011.
 14. Breunig, M. M., Kriegel, H.-P., Ng, R. T. and Sander, J. *LOF: identifying density-based local outliers*. ACM SIGMOD, 2000.
 15. Schölkopf, B., Platt, J. C., Shawe-Taylor, J., Smola, A. J. and Williamson, R. C. *Estimating the support of a high-dimensional distribution*. Neural Computation 13(7), 2001.
 16. Pedregosa, F. et al. *Scikit-learn: machine learning in Python*. Journal of Machine Learning Research 12, 2011.
 17. Page, E. S. *Continuous inspection schemes*. Biometrika 41(1/2), 1954.
 18. von Neumann, J. *Zur Theorie der Gesellschaftsspiele*. Mathematische Annalen 100(1), 1928.
 19. Dantzig, G. B. *A proof of the equivalence of the programming problem and the game problem*. In Koopmans, T. C. (ed.), *Activity Analysis of Production and Allocation*, Wiley, 1951.
 20. Auer, P., Cesa-Bianchi, N., Freund, Y. and Schapire, R. E. *The nonstochastic multiarmed bandit problem*. SIAM Journal on Computing 32(1), 2002.
-

Appendix A. Data and evaluation design

The Los Alamos comprehensive cyber-security events data set [2], released CCo: 1.05 billion authentication events over 58 days from 12,425 users and 17,684 computers, with a labelled red-team exercise embedded. A record carries nine fields; an uninterpretable value is written `?`, a distinct state from absence and treated as one throughout.

The unit of analysis is a human account; machine accounts, `SYSTEM` and `ANONYMOUS LOGON` are excluded at no cost in labels, since all 104 accounts the red team touched are human. The label file carries 749 rows, 715 distinct, naming those 104, and is highly concentrated: 93.6% of rows share one source computer, and two of seven scored days carry 482 of the 700 post-boundary labels. It records what the red team did and is not an exhaustive annotation, so malicious activity it missed counts as a false positive and **every precision figure in this paper is a lower bound**. Failed authentications appear only for accounts that succeeded somewhere in the data set, so the failure population is conditioned on eventual success — a property of the archive rather than of a live stream, and one the arms score.

Windows. The first seven days are a burn-in window: events are scored, so state warms under exactly the code path scoring uses, but nothing is emitted or counted. Two quantities are fitted there and frozen at the boundary — a between-arm covariance and a conformal calibration (§4.3) — and neither is ever updated by an event it is later used to score. The window was fixed before any end-to-end measurement and costs the 49 labelled events inside it. Scoring runs over days 7–13.

Sampling. Three of four designs are entity samples, because a fixed alerts-per-day budget is a far harder target on 42.2 million events than on 4.2 million. Every labelled account is retained in every sample, which inflates the labelled share, so each base rate is stated.

DESIGN	SELECTOR	SCORED EVENTS	LABELLED	BASE RATE
full	none	42,218,530	549	1.30×10^{-5}
r11	1 entity in 16, residue 11	4,190,603	549	1.31×10^{-4}
inj	1 entity in 16, residue 7, plus planted attacks	4,494,396	1,405	3.13×10^{-4}
holdout-r7	days 7–8 of the residue-7 corpus	1,427,225	262	1.84×10^{-4}

Because labelled accounts are exempt from sampling, the residue-7 and residue-11 corpora share their labelled events and differ only in background and window. A result reproduced across them is a check on sensitivity to background, not an independent replication.

Planted mechanisms. Six named kinds, eight victims each, entirely inside the scoring window. Victims are disjoint from every account the real labels name, so the account alone determines which ground truth an event belongs to.

MECHANISM	CONSTRUCTION	EVENTS	PREMISE ISOLATED
credential spray	many never-used destinations within ten minutes	320	categorical novelty and its rate
lateral chain	connected hops, each sourced from the previous destination	40	novel <i>pairings</i> of real values
off-hours	only familiar values, twelve hours from the account's window	64	the circular timing null alone
privilege escalation	an authentication type absent from the account's history	24	novelty on a low-cardinality field
low-and-slow	familiar values only, twelve extra events a day for three days	288	the volume null alone
account takeover	destination, authentication type, logon type and hour all change	120	an upper bound: everything at once

The decision that matters statistically is the choice of planted value: **the most population-common value the victim has never used**. Sampling the vocabulary uniformly instead plants population-rare values, and a population-rarity test then detects the plant for the wrong reason. Value choice is deterministic, so every victim of a kind receives the same planted values: the events of one kind are not independent draws and the effective sample size is nearer eight than the event count. Sensitivity against planted labels says whether a test responds to a mechanism, not whether it detects an intrusion, so the two ground truths are never summed.

Appendix B. The structural census

Before any arm, what property of a labelled event could a method exploit? We census five structural properties of an event relative to the history it was scored against, defined by facts about the event and the history and never by which arm produced the smallest p-value — a partition defined by our own arms would flatter the framework by construction. On `r11`, 4,190,603 scored events of which 549 are labelled:

PROPERTY	LABELLED	SHARE	BACKGROUND	SHARE	LIFT
novel pairing for this entity	362	65.9%	19,841	0.473%	139
novel value for this entity	215	39.2%	8,913	0.213%	184
volume burst for this entity	199	36.2%	1,143,820	27.3%	1.3
outside this entity's hours	181	33.0%	1,576,171	37.6%	0.9
population-rare value	0	0.0%	4,835	0.115%	0.0

The properties are not mutually exclusive and 92 labelled events exhibit none of them.

Population rarity is not merely weaker, it is **empty**: not one labelled event holds a population-rare value while 4,835 background events do, so a population-rarity test here is a test of something the campaign does not exhibit. That is the strongest form this paper's central claim takes, and it is a statement about this campaign — §2.2 shows the property behaving differently on planted attacks. Volume bursts and out-of-hours activity are not enriched at all, which bounds what work on those two arms could recover; §3.3 gives the other half of each explanation.

Appendix C. Requirements

	REQUIREMENT
R1	A verdict is a function of the event and of persisted state only, so scoring is reproducible from the record and independent of batching.
R2	No component requires advance knowledge of a field's type, cardinality or value set. One field must be declared the entity, and one the timestamp; nothing else.
R3	Abstention is an outcome. A component with no basis for an opinion says so, and does not contribute a neutral value.
R4	Scoring is deterministic: no wall clock, no randomness, and a canonical total order before every floating-point reduction.
R5	A verdict carries the evidence needed to reconstruct it.
R6	Alert volume follows from a stated exchange rate between a missed intrusion and a wasted investigation, not from a quota.

Appendix D. The likelihood-ratio allocation rule

Two quantities are fitted per arm on burn-in and frozen: a null over that arm's own log p-value, and the single parameter a of a $\text{Beta}(a, 1)$ density over the null quantiles its labelled burn-in events received. An alert at quantile q from an arm of weight a scores $s = \ln a + (a - 1) \ln q$, the log-likelihood ratio of its being labelled against its being background. Alerts from arms sharing no p-value scale are comparable on s , so the budget goes to the highest scores and no share parameter is chosen.

A weight is retained only where twice its log-likelihood ratio against $a = 1$ exceeds 2.706, the 5% one-sided point at the boundary of the range [10]; without that guard fifty uniform draws fit $a \approx 1 \pm 0.14$ and noise alone buys a large share of the queue. Labelled events an arm evaluated without surfacing enter right-censored.

The fit separates the arms as intended — on `r11` the three per-entity arms are informative at $a = 0.376$, 0.414 and 0.491, while `timing`, `volume` and the `marginal` surface none of the 49 labelled burn-in events and are fitted uninformative. §2.4 reports that it is not enough. One property survives and is why the implementation retains it: every quantity s reads is a property of the single alert or of state frozen before the window, so the same arithmetic that ranks a batch thresholds a stream.

Appendix E. Truncation at a stated exchange rate

At $v/c = 10$ as stated in §4.4, on the corrected-minimum arm:

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	30	4	5.7% → 13.3%	40 (57%)	0
100/day	700	47	221	47	6.7% → 21.3%	479 (68%)	0
1000/day	7,000	162	315	74	2.3% → 23.5%	6,685 (95%)	88

At the two tighter budgets the truncation is free. At 1000 it becomes a decision: the objective discards 6,685 alerts and 88 true positives with them, because at this rate those 88 do not pay for 6,685 wasted investigations. For the composite the optimum is to emit nothing at any budget, including the one at which it finds 113 true positives — an objective declining to deploy a detector is a usable answer. The optimum is located using the labels, so this measures headroom rather than being a deployable rule.

Reporting at a nominal false discovery rate is not available here. Benjamini–Hochberg [8] per day on the composite at $q = 0.05$ yields 5,352 discoveries of which 113 are labelled, a realised FDR of 0.979 (0.975–0.982) with five of seven days saturated; Benjamini–Yekutieli [9] gives 0.978 at $q = 0.001$. The nominal level has no purchase because the p-values are not calibrated — a property of the composite rather than of the procedures.

Appendix F. Threats to validity

§3.2 carries the two that dominate. The rest, each with the measurement establishing it and the direction it biases:

THREAT	MEASUREMENT	DIRECTION
effective sample far below nominal	549 events on 104 accounts; 93.6% of label rows share one computer; 8 victims per planted mechanism	every interval is optimistic
quantities chosen on the outcome	the best arm, the union's break-even rates, §2.4's split search, Appendix E's optimum; 7 arms × 5 rules × 3 budgets × 2 corpora, maxima reported	favours the framework; stated as oracle bounds, outer loop unadjusted
not measured at full population	the one full run scored 42,218,530 events with 4 of 7 arms; its composite detects nothing	a budget is far easier on a subset
Brown's correction unavailable	$\text{Var}[X^2] = -27.5$, which no joint distribution produces, so the estimate measures the marginals' misspecification rather than the arms' dependence	every composite figure is plain Fisher ; a corrected composite awaits calibrated marginals
entity-day aggregation flatters recall	65 of 108 entity-days at 100/day against 47 of 549 events, but Fisher's statistic at entity scope grows with the event count and the count-normalised form takes 65 to 14	most of the gain is the confound
§2.3 inherits its matrix's limits	event-level rates where the effective sample is nearer eight victims; lof from a 100× easier sample	lof is an existence proof, not a matched row; the adversary knows the allocation but not the realised draw

Appendix G. Adversary cost, and where work is worth spending

A value-zero equilibrium assumes an uncovered mechanism is free to mount, and low-and-slow is slow by construction. Charging λ times a stated per-mechanism cost, with low-and-slow at twelve times credential spray, on the strategy set with **lof** admitted so the mechanism being priced is one some arm reaches:

λ	VALUE	ALLOCATION	ADVERSARY'S REPLY
0	0.019	lof 0.47, timing 0.42, noveltyrate 0.12	low+slow 0.47, off-hrs 0.42, priv-esc 0.12
0.005	0.043	timing 0.80, noveltyrate 0.20	off-hrs 0.78, priv-esc 0.22

λ	VALUE	ALLOCATION	ADVERSARY'S REPLY
0.02	0.061	timing 0.87, noveltyrate 0.13	off-hrs 0.78, priv-esc 0.22
0.05	0.092	timing 0.89, noveltyrate 0.11	off-hrs 0.89, spray 0.11

Any appreciable cost removes low-and-slow from the reply. The costs and λ are stated, never fitted: a cost fitted to the labels the allocation is scored against would make the equilibrium a restatement of the corpus. The solution concept is properly Stackelberg, the defender committing first; for zero-sum games it coincides with §2.3's, and once mechanism costs differ it does not.

Shadow prices. Every cell whose improvement by 0.10 raises the guarantee lies in low-and-slow, off-hours or privilege escalation — the mechanisms in the adversary's reply. The largest are `timing` on low-and-slow (+0.017), `lof` on off-hours (+0.014) and `noveltyrate` on low-and-slow (+0.012). Not one lies in the four columns §2.1 and §2.2 compare arms on, and the two arms carrying every positive shadow price are the two §3.3 reports as unmeasured.

Data and code availability

Every number here is read from a machine-generated result file committed alongside the source, each carrying its run identifier, corpus checksums, row counts, seeds and parameters. No figure is a plot of data: each is a diagram of a mechanism, so no figure can disagree with a result. §2.3's equilibria are solved from the recorded per-mechanism matrix by `cmd/robust` and need no corpus, so they reproduce from this repository alone. The corpus is third-party and is not redistributed.

Generated by `cmd/thesis` from `docs/PAPER.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.